SRI LANKA INSTITUTE OF INFORMATION TECHNOLOGY

FACULTY OF COMPUTING.

WEB SECURITY- IE2062

IT22121592 – HERATH H.M.C.H.K

Y2S2

Contents

Subdomain Enumeration: 3
Vulnerability title. 3
Vulnerability description 3
Affected components. 4
Impact assessment 6
Step to reproduce. 9
Proposed mitigation or fix. 9

The subdomain grow.bigcommerce.com

Subdomain Enumeration:

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ nikto -h https://grow.bigcommerce.com
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Multiple IPs found: 104.17.71.206, 104.17.74.206, 104.17.73.206, 104.17.70.206, 104.17.72.206
+ Target IP:          104.17.71.206
+ Target Hostname:    grow.bigcommerce.com
+ Target Port:        443
---------------------------------------------------------------------------
```

Vulnerability title.

Unsecured cookies (mkt_lang)

Vulnerability description

Unprotected Cookies (mkt_lang) Vulnerability

An unsecured cookie vulnerability arises when cookies are inadequately safeguarded and can be exploited by parties to pilfer or tamper with them resulting in security threats, like session hijacking and cross-site scripting (XSS) well as information exposure risks. The cookie "mkt_lang" might be, at risk if it lacks the security settings.

Cookies store information related to a user's session data and preferences, in their browser and may also contain data that needs to be protected from access or scripts. When it comes to mkt_lang cookies that save user language preferences and marketing related settings the risk factor lies in the way these cookies are established and managed.

Affected components.

The vulnerability known as Unsecured Cookies (mk_lang_) impacts parts of a web applications framework related to the handling and transmission of cookies." These are the components that are affected:

Web application server:

In case the server fails to create cookies, with the security features (Secure, HttpOnly SameSite) cookies such as mkt_lang could be, at risk of being compromised.

The management of user sessions and cookies, by the server, can potentially put session information at risk if adequate security measures are not in place.

Misconfiguring the response headers by setting cookies could result in overlooking security attributes.

On the client side (in the browser):

If cookies are not labeled as HttpOnly secure, in the storage process they can be vulnerable to access and potential theft or tampering, by JavaScript running in the client-side environment.

Cross-site requests can potentially expose users to CSRF attacks if cookies are included without the SameSite attribute being specified.

Transport Layer (HTTP or HTTPS):

Without an attribute, in place during the transmission of data through cookies over HTTP connections leaves them vulnerable to potential man-in-the-middle (MITI attacks). Any network components such as proxies and routers, between the client and server could potentially be manipulated to intercept these cookies.

Session and authentication systems:

If session tokens or other confidential data, like mkt_lang, are saved in cookies without protection measures, in place. Falling into the wrong hands of a cyber intruder could potentially exploit them to take control of user sessions.

Authorization Methods Concerns; Insecure cookies could enable attackers to alter authorization or entry privileges by changing cookie values and potentially circumventing access restrictions.

External services, from providers (such, as APIs or CDNs):

When third-party integrations involve sharing cookies among domains or external services, like content delivery networks (CDNs) there is a risk of exposing information to these outside entities if proper cookie policies are not implemented securely.

Cross-Origin Requests Explanation; In the absence of the SameSite attribute setting in cookies, external websites could potentially exploit this gap via origin requests that might result in CSRF attacks.

Marketing systems:

When using mkt_lang to save user language or marketing preferences it's important to be cautious, about cookies that could be used by attackers to tamper with marketing settings This could result in tracking information or manipulation of user behavior.

If the cookie contains details utilized for tailored content presentation like language preferences, entry, into this cookie might lead to a misrepresentation of user tastes or deceptive targeted advertising practices.

Impact assessment.

1. **Session Hijacking:**

If cookies such, as mkt_lang are not adequately protected against access or tampering by actors could result in the compromise of a user's session and potentially grant them unauthorized access to user accounts. Enabling them to impersonate the legitimate user with impunity Imagine someone gaining control of your login session and altering your account details or carrying out transactions using your identity This type of weakness poses a significant threat, to personal data security and privacy.

- Real-world consequences include loss of control, over your account and the risk of identity theft.
- The impact could be significant if critical information or user sessions are compromised.

2. **Cross-site-scripting (XSS)**

If cookies can be accessed by scripts running on the client side of a website it provides an opportunity for malicious individuals to insert code into the site This might enable them to take or tamper with your cookies For example they could execute scripts in your web browser to pilfer session tokens potentially allowing them to pose as you on a website.

- Real-world consequences can include stolen information or unauthorized use of your account.
- The level of seriousness ranges from moderate to significant based on the purpose of the cookie.

3. **Cross-Site Request Forgery (CSRF)**

If you don't have the security measures, in place when you're online, someone could deceive you into doing things you didn't mean to. Such as clicking on a link that alters your account details. The website sees your cookie as trustworthy because you're logged in,<Organization> while the attacker is manipulating it to work for them.

- Real-world consequences include modifications, to your account or activities carried out on your behalf.
- Significance is significant, for websites where you conduct tasks, like banking or updating account information.

4. **Man-in-the-middle Attacks.**

When you send the cookie over a connection (using HTTP or HTTPS) there's a risk that a hacker, on the same network could intercept it easily. Think about being, on Wi-Fi and someone grabbing your cookies while you're online. They could potentially get into your account. Alter your settings.

- Real-world consequences include the risk of cookie theft when using networks such, as Wi-Fi.
- The risk is significant when the cookie includes login or session information.

5. **Marketing preferences and personalization.**

This cookie could save details such, as your preferred language or marketing preferences. If someone alters this information dishonestly it may not appear significant initially. However, it could disrupt your website experience, distort marketing data, or potentially permit the insertion of content.

- Real-world consequences include using the language settings which can lead to a user experience and inaccurate tracking of data metrics.
- The level of severity ranges from low to medium based on the importance of these settings, to the website.

6. **Loss of user confidence and damage and brand reputation**

When individuals discover that their data or sessions have been compromised by access or breaches, in security measures trust becomes a commodity that is challenging to restore to its original state of confidence and reliability. If such vulnerabilities are exploited on a scale within an organization's system infrastructure or network it has the potential to severely impact the company's standing and credibility among its user base and the wider community. As a result of these breaches in security measures and data compromises, individuals may no longer feel secure or safe while using the service provided which could lead to a loss, in user engagement and loyalty as people naturally prefer platforms and services that prioritize their cybersecurity needs and protect their information from access.

- Real-world consequences include a decline, in user numbers, unfavorable media coverage, and a decrease, in revenue.
- The level of seriousness is high, for businesses that heavily depend on user trust such, as e-commerce and financial services.

7. **Violation of regulations**

Exposing data due to insecure cookies could result in penalties and legal repercussions, under data protection laws such as GDPR that impose rules, for companies concerning the handling and safeguarding of personal information; failure to comply may lead to financial sanctions.

- Real-world implications include facing ramifications and monetary penalties, for mishandling user data.
- The level of seriousness is significant for businesses that are, under frameworks such, as GDPR.

8. **Third-Party exploits.**

If this cookie is used on websites or services (which often happens with marketing cookies) attackers might take advantage of vulnerabilities, in one site to target another one well Cross-site problems could emerge that would allow attackers to nab information or tamper with the cookie, on various platforms.

- The actual consequences could involve your data being shared among websites or platforms that you engage with regularly.
- The impact could be moderate if data is exchanged between domains or services.

Step to reproduce.

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ nikto -h https://grow.bigcommerce.com
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Multiple IPs found: 104.17.71.206, 104.17.74.206, 104.17.73.206, 104.17.70.206, 104.17.72.206
+ Target IP:          104.17.71.206
+ Target Hostname:    grow.bigcommerce.com
+ Target Port:        443
---------------------------------------------------------------------------
```

```
---------------------------------------------------------------------------
+ Server: cloudflare
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ /:  IP address found in the '__cf_bm' cookie. The IP is "1.0.1.1".
+ Root page / redirects to: https://www.bigcommerce.com
+ /wKevwE8j.html: Uncommon header 'x-mkto-nginx-cache' found, with contents: true.
+ /wKevwE8j.html: Uncommon header 'x-cache-status' found, with contents: MISS.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /rs/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnera
```

Proposed mitigation or fix.

Ensure that cookies are transmitted through connections to enhance data security.

It's important to make sure that the mkt_lang cookie is transmitted on HTTPS) connections to prevent interception, on public networks like sending a letter without sealing it for anyone to read easily.

- Here's how you can solve the issue- Include the Secure attribute, in the cookie to ensure it's transmitted when the connection is secure and encrypted This way your data stays protected from eavesdroppers especially when using a public Wi-Fi network.

Prevent JavaScript from Accessing your cookies.

To address this issue effectively, Enable the HttpOnly attribute, for the cookie to restrict access to the server only and prevent access by hackers who may attempt to exploit scripts to hijack your cookie and gain access, to your session information.

If you don't take precautions online. Safeguard your browsing activities adequately against threats, from hackers and unauthorized access attempts by malicious actors who may manipulate your browser without your awareness or consent to carry out various actions on different websites such as altering configurations or submitting information without your authorization due, to the automatic transmission of cookies by your browser even when you're browsing other sites.

- Here's how you can solve this issue- Simply include the SameSite attribute, in the cookie settings to instruct the browser to only transmit the cookie data when you are actively engaging with the site and not when you are browsing across websites through links.

Ensure restrictions on the cookies usage location.

Why? : It's not necessary for every section of your website to have access, to all cookies. By limiting the areas of your website that can utilize cookies you can lower the chances of misuse.

- Here's how to fix it: One way to address this is, by defining domains and routes where the cookie is applicable; for instance limit its usage to a subdomain or a specific section of the website if thats all that’s necessary.

Avoid storing data in cookies.

It's not an idea to store information such, as passwords or session tokens in cookies because they are not very secure. If a hacker manages to obtain the cookie somehow they could gain access, to sensitive data.

- Here's a possible way to fix it: To address the issue at hand, Refrain from including details in cookies and opt for encryption when necessary to safeguard data from unauthorized access, in case of a cookie breach.

Ensure to incorporate a Content Security Policy (CSP).

To avoid scripts from infiltrating your website it's akin, to having a gatekeeper who permits only authorized scripts to enter.

- Here's a suggestion for improvement: Establish a Content Security Policy outlining the authorized scripts, for your website to deter hackers from inserting code that could potentially compromise cookie data.

Secure the Cookie Information

When a cookie contains information such, as user preferences and is **encrypted** appropriately it safeguards the data within, from being accessed or utilized in any way if the cookie is unlawfully obtained.

- Here's a way to solve this issue: Encrypt the information, in the cookie using encryption methods and only permit the server to decode it when necessary.

Make sure to check and test your cookies to ensure they're working properly.

Reason: As time passes by changes occur—fresh vulnerabilities could surface or new functionalities may impact the way your cookies are utilized. If you consistently monitor the configuration of your cookies it will aid in detecting problems at a stage.

- Make it a habit to regularly check your cookie settings to ensure they are secure and properly configured for safety measures.